



Government
Digital Service



Department for
Science, Innovation
& Technology

Distributed denial-of-service (DDoS) response strategy: Alignment with Secure By Design

Aug 2025

Contents

Background.....	4
Purpose.....	4
More about Secure by Design.....	4
1. DDoS response strategy.....	5
Preparation and planning.....	5
Prevention and protection.....	5
Detection and response.....	6
Post-incident analysis and continuous improvement.....	6
2. Components of a DDoS Response Strategy.....	7
2.1 Preparation and risk assessment.....	7
2.2 DDoS protection measures.....	7
2.3 Monitoring and detection.....	8
2.4 Incident response plan.....	9
2.5 Communication plan.....	9
2.6 Mitigation and containment.....	10
2.7 Post-attack analysis and recovery.....	10
2.8 Testing and updating the DDoS response strategy.....	11
2.9 Legal and compliance considerations.....	11
3. Aligning DDoS response strategy with Secure by Design.....	13
3.1 Preparation and risk assessment → Secure planning from the start.....	13
3.2 DDoS protection measures → Resilience built into the architecture.....	14
3.3 Monitoring and detection → Built-in observability and alerting.....	14
3.4 Incident response plan → Engineered for fast, predictable response.....	15
3.5 Communication plan → Secure, transparent information flow.....	15
3.6 Mitigation and containment → Systems designed to withstand and recover.....	16
3.7 Post-attack analysis and recovery → Built-in feedback loop.....	16
3.8 Testing and updating the strategy → Continuous validation built in.....	16
3.9 Legal and compliance considerations → Policy and governance built in.....	17
4. Aligning DDoS response strategy with project delivery phases.....	18
4.1 Initiation phase: Establish awareness and requirements.....	18
4.2 Planning phase: Prepare the project roadmap and detailed strategies.....	18
4.3 Execution / development phase: Build and implement the system.....	19
4.4 Testing phase: Validate system performance, security and resilience.....	19
4.5 Deployment / implementation phase: Launch the system into production.....	19
4.6 Maintenance / operation phase: Maintain availability, performance, and security...20	
4.7 Closing / review phase: Evaluate project outcomes and lessons learned.....20	

5. DDoS protection best practices.....	21
5.1 Infrastructure and network-level best practices.....	21
5.2 Application-layer (layer 7) best practices.....	22
5.3 Cloud and third-party services.....	23
5.4 Detection and monitoring.....	24
5.5 Incident response and recovery.....	25
5.6 Ongoing security hygiene and improvement.....	25
6. DDoS incidents reporting.....	27
7. More information.....	28

Background

Distributed denial-of-service (DDoS) protection is a critical cyber security measure designed to safeguard networks, servers and applications from malicious attacks that aim to overwhelm and disrupt normal traffic. These attacks typically involve multiple compromised systems flooding a target with a massive volume of requests, rendering services unavailable to legitimate users.

A robust DDoS protection strategy involves a multi-layered approach that combines prevention, detection and response.

Purpose

The purpose of this document is to outline the DDoS response strategy, best practices and guidance. This document also covers the alignment of the government [Secure By Design](#) approach with the DDoS response strategy.

More about Secure by Design

[Secure by Design policy](#)

[Implementing Secure by Design](#)

[Guide to adopting Secure by Design](#)

1. DDoS response strategy

A DDoS response strategy is a structured approach to prepare for, detect, mitigate and recover from DDoS attacks.

Preparation and planning

A DDoS response strategy begins with thorough preparation and planning, which are essential to reducing the impact of potential attacks. This includes identifying and prioritising critical assets such as web servers, APIs, DNS infrastructure and authentication services that, if disrupted, could cause significant operational or reputational harm.

Organisations must assess the likelihood and potential consequences of different DDoS scenarios, ranging from volumetric floods to more targeted application-layer attacks. A formal incident response plan should be developed, outlining roles, responsibilities, escalation paths, and communication protocols. This plan should be regularly updated and include coordination with internet service providers (ISPs), content delivery networks (CDNs), and cloud-based DDoS protection vendors. In parallel, internal teams, especially IT, security and communications, must be trained to recognise early warning signs of a DDoS incident and to execute the response plan effectively. If there is no distinct role responsible for the planning activities it needs to be coordinated with the third-party service providers by the relevant team from the organisation to ensure planning completion and future maintenance.

Prevention and protection

Preventive and protective measures are the foundation of any effective DDoS defense. These should be implemented across multiple layers of the infrastructure to reduce the attack surface and absorb malicious traffic.

Network-level protections may include firewalls, intrusion prevention systems (IPS) and traffic rate limiting, while application-layer defenses rely on web application firewalls (WAFs), CAPTCHA mechanisms, and API gateways. Cloud-based DDoS mitigation services, such as Cloudflare, Akamai, AWS Shield, or Azure DDoS Protection, can help absorb large-scale traffic surges and scrub malicious requests before they reach your service.

Organisations should also use CDNs to cache static content and reduce direct server loads. Redundancy and scalability, through load balancing, auto-scaling groups and geographically distributed systems, are key to maintaining service availability during sustained attacks. Additionally, secure configurations and default-deny rules should be enforced on public-facing services to minimise unnecessary exposure.

Detection and response

Detection and response capabilities must be integrated into normal operations to allow for real-time monitoring and rapid action during an attack (see the [Secure by Design Principles](#)). Traffic monitoring tools and Security Information and Event Management (SIEM) systems should be configured to detect anomalies in network behaviour (see the Secure by Design activity [Managing observability](#)), such as sudden traffic spikes, high numbers of SYN packets or a surge in HTTP requests. Baselines for 'normal' traffic should be established to support early detection of potential attacks. When a DDoS attack is confirmed, the incident response plan should be activated immediately, with clear coordination between technical, leadership and communications teams.

Response actions may include:

- blocking or throttling traffic by IP, region, or protocol
- redirecting traffic through scrubbing centers
- isolating impacted systems
- initiating failover to backup infrastructure

Simultaneously, clear and timely communication with customers, stakeholders, and possibly law enforcement is essential to maintain trust, manage expectations and meet regulatory requirements.

Post-incident analysis and continuous improvement

Finally, effective DDoS resilience requires a commitment to post-incident analysis and continuous improvement. After an attack, a detailed forensic review should be conducted to determine the method, source and impact of the attack, as well as to assess the effectiveness of the mitigation efforts. To prevent similar attacks in the future, lessons learned should inform:

- updates to the response plan
- adjustments to security controls
- architectural changes

Regular training, simulation exercises and red team drills help maintain readiness and ensure staff know their roles during real incidents. Testing should also extend to backup systems and failover mechanisms to confirm that they can handle sudden traffic shifts.

By continuously evaluating the threat landscape, updating technical defenses and refining operational processes, organisations can ensure their DDoS response strategy remains agile and effective in the face of evolving threats.

2. Components of a DDoS Response Strategy

2.1 Preparation and risk assessment

Establish a clear understanding of potential vulnerabilities, threat landscape and your organisation's risk exposure.

Key actions

- **Asset identification:** Document critical assets like customer portals, APIs, DNS infrastructure, databases, and payment gateways.
- **Threat intelligence:** Subscribe to threat feeds and services that provide information on active DDoS campaigns or known threat actors.
- **Business impact analysis (BIA):** Assess how a DDoS attack would affect operations, revenue, reputation, and customer trust.
- **Risk prioritisation:** Rank assets by criticality and risk level to determine which systems require enhanced protection.

Related Secure by Design activities

[Considering security within the business case](#)

[Identifying security resources](#)

[Working out the project's security risk appetite](#)

2.2 DDoS protection measures

Implement layered defenses to reduce the chance of successful DDoS attacks and mitigate their impact.

Key measures

- **Web Application Firewalls (WAFs):** Protect against layer 7 (application layer) attacks by filtering malicious HTTP/S traffic.
- **Rate limiting:** Restrict the number of requests from a single source over a time period to slow down attack traffic.
- **Reverse proxies and CDN caching:** Absorb traffic at the edge and reduce load on origin servers.
- **Geo-blocking and IP reputation services:** Deny or challenge traffic from known botnets or high-risk regions.

Cloud-based DDoS mitigation services: Use providers like *Cloudflare*, *Akamai*, *AWS Shield*, *Google Cloud Armor*. These services offer large-scale bandwidth and advanced filtering capabilities.

Related Secure by Design activities

[Agreeing a security controls set for your service](#)

[Responding to and mitigating security risks](#)

[Assessing the effectiveness of security controls](#)

2.3 Monitoring and detection

Enable early detection of unusual traffic patterns to trigger a timely response.

Key actions

- **Establish traffic baselines:** Use historical data to define normal patterns across times of day, days of the week, and peak periods.
- **Configure real-time monitoring and logging tools:**
- **Anomaly detection:** Deploy machine learning tools which flag traffic anomalies automatically.
- **Automated alerting:** Configure thresholds to generate alerts for traffic spikes, unusual packet types, or protocol-specific anomalies.

Related cyber security guidance

[Secure by Design activities](#)

[Implementing Secure by Design](#)

[Logging and protective monitoring \(NCSC.GOV.UK\)](#)

[Security monitoring \(NCSC.GOV.UK\)](#)

2.4 Incident response plan

Provide a clear, documented roadmap for detecting, analysing and mitigating DDoS attacks.

Key components

- **Runbooks and playbooks:**
 - For volumetric attacks: Engage scrubbing centers, reroute traffic
 - For protocol attacks: Adjust firewall rules, limit malformed packets
 - For application-layer attacks: Enable CAPTCHA, enforce stronger authentication, use multi-factor authentication (MFA)
- **Defined roles/responsibilities:**
 - Incident commander, technical lead, network engineers, comms team, legal liaison
- **Escalation paths:** Who to notify and when, internal and external contacts
- **Coordination with ISPs and vendors:** Have pre-established relationships for rapid response.

Related cyber security guidance

[Secure by Design activities](#)

[Plan: Your cyber incident response processes \(NCSC.GOV.UK\)](#)

[Incident management \(NCSC.GOV.UK\)](#)

[Cyber Incident Response \(CIR\) \(NCSC.GOV.UK\)](#)

2.5 Communication plan

Maintain transparency, reduce panic and protect the organisation's reputation during and after an attack.

Key components

- **Internal communication:**
 - Alert IT, executive leadership and customer support teams.
 - Use secure, out-of-band channels (for example, Signal or secure email) if primary systems are down.
- **Customer and partner updates:**
 - Use status pages (for example, [statuspage.io](#)), email and social media.
 - Avoid technical jargon. Explain what's happening in business-friendly terms.
- **Media strategy:**
 - Prepare press releases or talking points for media inquiries.
 - Designate a spokesperson.

- **Law enforcement contact:**
 - For high-impact attacks or extortion attempts (for example, ransom DDoS), involve appropriate authorities (for example, Computer Emergency Response Teams (CERT) and the relevant government bodies).

Related Secure by Design guidance

[Implementing Secure by Design](#)

2.6 Mitigation and containment

Actively reduce the impact of the attack and restore service availability.

Key techniques

- **Activate mitigation partners:** Notify your cloud DDoS protection provider to reroute or scrub traffic.
- **Traffic diversion:**
 - Use DNS failover or Border Gateway Protocol (BGP) anycast to direct traffic through mitigation networks.
- **Rate limiting and blocking:**
 - Drop or challenge requests from known bad actors or abusive IPs.
 - Use CAPTCHA, JavaScript challenges or MFA.
- **Scaling infrastructure:**
 - Use autoscaling groups, horizontal scaling or redundant servers to absorb load.
- **Isolate affected systems:**
 - Segregate infected or overwhelmed segments of the network to prevent lateral impact.

2.7 Post-attack analysis and recovery

Learn from the attack, patch vulnerabilities and prepare better for future incidents.

Key activities

- **Root cause analysis:**
 - What type of DDoS was used? What vectors? What was the source?
- **Forensic review:**
 - Analyse network logs, application logs and firewall logs.
 - Identify command-and-control patterns, botnet behaviour.
- **Patch and harden systems:**
 - Apply security updates.
 - Disable unused services and enforce stricter access controls.
- **Stakeholder debrief:**
 - Hold a post-incident review (PIR) with all involved teams.
 - Discuss what worked, what failed and what could be improved.

- **Risk management:**
 - Recognise that a risk has crystallised.
 - Reconsider mitigations and keep risk-management SMEs informed about remediation.
- **Customer follow-up:**
 - Share transparency reports, apologise for any inconvenience and explain next steps.

2.8 Testing and updating the DDoS response strategy

Ensure the DDoS response plan remains effective and up to date.

Key activities

- **Simulation drills:**
 - Run red team or blue team exercises.
 - Simulate attack types (volumetric, application, protocol-level) to test readiness.
- **Tabletop exercises:**
 - Walk through scenarios with key personnel to validate response coordination.
- **Update documentation:**
 - Reflect changes in technology, infrastructure or threat landscape.
- **Staff training:**
 - Regularly train IT, security operations centre (SOC) and DevOps teams on DDoS mitigation tactics and tools.

2.9 Legal and compliance considerations

Ensure compliance with laws and regulations.

[Cyber security regulations in the UK \(NCSC.GOV.UK\)](https://www.ncsc.gov.uk/section/1/10)

Key considerations

- **Data protection laws:**
 - If customer data is affected, follow regulations like GDPR and the Data Protection Act (DPA).
- **Breach notification laws:**
 - Some jurisdictions require public notification within a specific timeframe.
[Personal data breaches: a guide \(ICO\)](#)
- **Cyber insurance:**
 - Review your policy: Are DDoS attacks covered? What's the claims process?
- **Preserve evidence:**
 - Log and store evidence securely in case of investigations or litigation.

A robust DDoS response strategy is not just technical - it involves people, processes and planning. Regular updates, testing and training are essential to staying resilient against the evolving threat landscape.

3. Aligning DDoS response strategy with Secure by Design

Aligning a DDoS response strategy with [Secure by Design principles](#) ensures that resilience to denial-of-service attacks is embedded into systems from the outset, rather than added reactively.

This involves:

- integrating threat modeling for DDoS attacks during the design phase
- minimising the attack surface through secure configurations
- building in default protections such as rate limiting, traffic filtering and redundant architectures

Monitoring, alerting, and automated response capabilities are treated as core system features, not optional add-ons. Secure by Design also emphasises continuous validation through testing and simulation, along with clear communication and governance structures to manage incidents effectively.

By aligning DDoS strategy with these principles, organisations create systems that are not only defensible but are inherently resilient and recoverable by design.

3.1 Preparation and risk assessment → Secure planning from the start

Objectives

- Understand the attack surface
- Identify critical systems and their exposure
- Ensure architectural decisions anticipate DDoS risks

Secure by Design integration

- **Threat modeling early in life cycle:**
 - Include DDoS as a distinct threat in initial threat models.
 - Identify potential DDoS vectors (for example, application layer, network layer, protocol exploits) during design. Use frameworks like STRIDE or MITRE ATT&CK.
- **Attack surface mapping:**
 - Identify public endpoints (for example, login pages, DNS, APIs) exposed to potential attackers.
 - Flag unnecessary exposure of ports or services and eliminate or limit access.
- **Business Impact Analysis (BIA):**
 - Determine how downtime affects customers, partners, and operations.
 - Use this data to prioritise mitigation investments (for example, protect revenue-generating services first).

3.2 DDoS protection measures → Resilience built into the architecture

Objectives

- Embed prevention and resistance mechanisms into infrastructure and software
- Prevent reliance on manual or reactive measures

Secure by Design integration

- **Default security controls:**
 - Use firewalls, WAFs, and DDoS scrubbing tools as **default components** in your infrastructure.
- **Layered defense architecture:**
 - Combine network-level (L3/L4) protection with application-layer (L7) filtering.
 - Employ reverse proxies, CDNs, and load balancers as integral components, not add-ons.
- **Fail-secure designs:**
 - Build services to degrade gracefully under attack (for example, static pages served if dynamic systems fail).
- **Zero trust and least privilege:**
 - Minimise open network access and validate every connection.
 - Remove unused protocols and ports by default.

3.3 Monitoring and detection → Built-in observability and alerting

Objectives

- Detect DDoS attacks as early as possible
- Monitor for both high and low volume anomalies

Secure by Design integration

- **Comprehensive telemetry design:**
 - Design systems to emit logs, metrics and alerts as a standard capability.
 - Integrate SIEM or centralised logging at deployment time.
- **Baselining normal traffic:**
 - Use ML or statistical tools to profile 'normal' behaviour to detect anomalies.
 - Regularly recalibrate to reflect changes in traffic or user patterns.
- **Secure logging practices:**
 - Logs must be tamper-resistant, timestamped and retained according to compliance requirements.
- **Real-time alerting and automation:**
 - Connect alerts to automation tools to trigger mitigation without human delay.

3.4 Incident response plan → Engineered for fast, predictable response

Objectives

- Ensure rapid, coordinated and consistent action during a DDoS incident
- Avoid ad-hoc responses that increase risk

Secure by Design integration

- **Predefined playbooks:**
 - Create detailed procedures for different attack types, updated regularly.
 - Include mitigation activation, communications and failover processes.
- **Integrated response tools:**
 - Embed response tools (for example, IP blacklists, geofencing, rate limiting) into your CI/CD and monitoring stack.
- **Role assignment:**
 - Define and assign roles before incidents: incident lead, technical coordinator, communications officer and so on.
- **Runbook as Code:**
 - Automate parts of the response (for example, blocking IPs or scaling services) using Infrastructure as Code (IaC) and runbooks.

3.5 Communication plan → Secure, transparent information flow

Objectives

- Ensure fast, accurate internal and external communication
- Preserve trust with customers and stakeholders

Secure by Design integration

- **Out-of-band communication channels:**
 - Establish secure, alternative communication methods if main channels are compromised (for example, encrypted messaging apps, separate VPNs).
- **Prepared messaging templates:**
 - Draft and pre-approve communications for various audiences (execs, partners, customers and media).
- **Reputation and trust management:**
 - Include crisis communication strategies in incident response.
- **Legal co-ordination:**
 - Ensure legal teams validate messaging against regulations and contracts.

3.6 Mitigation and containment → Systems designed to withstand and recover

Objectives

- Isolate and contain the effects of a DDoS attack
- Maintain service availability where possible

Secure by Design integration

- **Built-in auto-scaling:**
 - Architect cloud infrastructure to scale dynamically during spikes (within cost limits).
- **Traffic segmentation and filtering:**
 - Enable internal segmentation to isolate compromised zones.
 - Implement default deny rules and blocklists as code.
- **Failover mechanisms:**
 - Use multi-region or multi-cloud redundancy.
 - Automate DNS-based or BGP-level traffic rerouting.
- **Rate-limiting and CAPTCHAs:**
 - Protect endpoints like login or search forms from layer 7 attacks by default.

3.7 Post-attack analysis and recovery → Built-in feedback loop

Objectives

- Learn from each incident
- Use lessons to improve design and operations

Secure by Design integration

- **Automated log collection and retention:**
 - Systems are configured to preserve logs during attacks and store them securely.
- **Post-mortem process built into operations:**
 - Every incident triggers a review that feeds back into architecture, code and response plans.
- **Design for recovery:**
 - Systems include automation for restoring services from known-good states.
 - Ensure configurations are version-controlled and immutable.

3.8 Testing and updating the strategy → Continuous validation built in

Objectives

- Regularly validate that controls, responses and defenses work as designed

Secure by Design integration

- **Red team and simulation exercises:**
 - Conduct simulated DDoS attacks to test both technical and human responses.
- **CI/CD pipeline testing:**
 - Integrate DDoS response tests (for example, rate limiting validation) in deployment cycles.
- **Version control of response plans:**
 - Maintain playbooks and detection logic in version-controlled systems with auditable changes.
- **Adaptive controls:**
 - Automatically tune thresholds based on evolving traffic patterns and new threat intelligence.

[Responding to a DoS attack \(NCSC.GOV.UK\)](https://www.ncsc.gov.uk/section/104)

3.9 Legal and compliance considerations → Policy and governance built in

Objectives

- Ensure DDoS response activities align with legal, regulatory and contractual obligations

Secure by Design integration

- **Pre-mapped legal reporting triggers:**
 - Build compliance notifications and escalation paths into your IR plan.
- **Data residency and retention:**
 - Design systems to retain only necessary logs and data and store them in compliant regions.
- **Cyber insurance integration:**
 - Design incident processes to align with insurance requirements (for example, notify within service-level agreement (SLA), preserve evidence).
- **Vendor and third-party security controls:**
 - Ensure DDoS protections are part of vendor onboarding and contracts (for example, CDN providers, DNS registrars).

4. Aligning DDoS response strategy with project delivery phases

Aligning a DDoS response strategy with the project life cycle phases ensures that protection against denial-of-service attacks is considered throughout the development and deployment of a system.

During the **initiation and planning phase**, DDoS risks should be identified through threat modeling and included in the risk management plan.

In the **design phase**, architects should incorporate resilient infrastructure elements such as load balancers, content delivery networks (CDNs), and traffic filtering mechanisms.

The **development phase** should implement secure coding practices and rate-limiting logic to reduce exposure to application-layer attacks.

During **testing**, simulate DDoS scenarios to validate system behaviour under stress and evaluate mitigation effectiveness.

In the **deployment phase**, ensure that monitoring, alerting, and automated response tools are configured and integrated.

Finally, in the **maintenance phase**, regularly review logs, test response plans, update protections, and conduct post-incident reviews to continuously improve readiness.

This phased alignment helps ensure that DDoS resilience is systematically addressed, reducing the risk of disruption after launch.

4.1 Initiation phase: Establish awareness and requirements

DDoS strategy alignment

- **Risk assessment:** Identify DDoS as a potential threat in the project's risk register.
- **Stakeholder buy-in:** Educate stakeholders about DDoS risks and consequences.
- **Define objectives:** Ensure resilience and uptime requirements are part of the project scope.
- **Budget planning:** Allocate funds for DDoS mitigation services (for example, WAF, CDN, anti-DDoS vendors).

4.2 Planning phase: Prepare the project roadmap and detailed strategies

DDoS strategy alignment

- **Threat modeling:** Identify attack surfaces that could be targeted.
- **Define RTO and RPO:** Set Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) for services.

- **DDoS response plan:** Develop or refine an incident response plan specific to DDoS.
- **Vendor evaluation:** Choose DDoS mitigation vendors (for example, Cloudflare, AWS Shield, Akamai).
- **Capacity planning:** Design for scalability and traffic surges (auto-scaling, load balancing).

4.3 Execution / development phase: Build and implement the system

DDoS strategy alignment

- **Secure architecture:** Implement network and application layer protections.
- **Rate limiting and filtering:** Integrate protections like rate limiting, IP filtering, and geo-blocking.
- **Logging and monitoring setup:** Deploy traffic monitoring, logging, and anomaly detection tools.
- **Failover planning:** Set up redundant infrastructure and failover mechanisms (for example, multi-region deployments).

4.4 Testing phase: Validate system performance, security and resilience

DDoS strategy alignment

- **Penetration testing:** Include volumetric and application-layer DDoS scenarios.
- **Simulated attacks:** Run DDoS simulation tools (for example, Low Orbit Ion Cannon (LOIC), custom scripts, or vendor-assisted tests).
- **Response drills:** Conduct tabletop exercises or red team drills involving DDoS scenarios.
- **Performance benchmarking:** Ensure system can handle expected load + buffer for DDoS.

4.5 Deployment / implementation phase: Launch the system into production

DDoS strategy alignment

- **Activate DDoS protection:** Enable real-time DDoS protection from vendors.
- **Baseline traffic monitoring:** Establish baseline traffic behaviour for anomaly detection.
- **Alerting and escalation paths:** Ensure teams are trained and alerts are configured.

4.6 Maintenance / operation phase: Maintain availability, performance, and security

DDoS strategy alignment

- **24/7 monitoring:** Use SIEM tools and dashboards to watch for suspicious activity.
- **Incident response readiness:** Keep DDoS response runbooks updated and accessible.
- **Post-incident review:** After a DDoS event, perform root cause analysis and update plans.
- **Regular drills and updates:** Run periodic DDoS tests and update threat models.

4.7 Closing / review phase: Evaluate project outcomes and lessons learned

DDoS strategy alignment

- **Review DDoS readiness:** Document successes, failures and improvements for future projects.
- **Knowledge transfer:** Ensure lessons learned are shared with other teams or departments.
- **Compliance checks:** Ensure all DDoS mitigation aligns with legal, compliance and SLA requirements.

5. DDoS protection best practices

This section covers prescriptive guidance to build DDoS-resilient services following industry best practices.

5.1 Infrastructure and network-level best practices

Redundant and distributed architecture

A resilient network design begins with distributing workloads across multiple data centers, and cloud availability zones.

By implementing redundancy through active-active or active-passive configurations, organisations reduce the risk of a single point of failure during an attack. This geographic and logical distribution helps absorb and reroute traffic, ensuring that even if one site is targeted, others can continue delivering services without disruption.

Load balancing

Load balancing is essential for managing traffic evenly across servers, preventing any single system from becoming overwhelmed. This is particularly useful during DDoS attacks when malicious traffic floods the network.

Whether at the DNS level or via layer 4/7 load balancers, this mechanism allows traffic to be distributed intelligently, maintaining performance and availability even during peak load scenarios.

Minimise public exposure

Reducing the number of publicly accessible services is a core part of DDoS defense. Services that do not need to be internet-facing should be restricted to internal or private networks. This limits the number of potential targets and ensures that only essential applications are exposed to the public internet, minimising the overall attack surface.

Access control lists (ACLs)

Access control lists (ACLs) implemented on routers, firewalls, or network appliances can help block unwanted traffic before it enters the network.

By filtering traffic based on IP addresses, geolocation, or protocol types, ACLs allow administrators to proactively block known malicious sources and limit access to sensitive services during periods of heightened threat.

Anycast routing

Anycast is a routing method that enables the same IP address to be advertised from multiple locations.

During a DDoS attack, this setup automatically routes traffic to the nearest or least-congested server, helping to distribute the load and absorb volumetric attacks more

effectively. It also improves user experience by reducing latency and increasing the reliability of global services.

5.2 Application-layer (layer 7) best practices

Web application firewall (WAF)

A web application firewall acts as a gatekeeper between users and web servers, inspecting HTTP/S traffic and blocking malicious requests based on predefined security rules. It is especially effective against layer 7 attacks that target application logic, such as HTTP floods or malicious payloads.

A well-configured WAF helps stop automated bots and protects against known vulnerabilities like SQL injection or cross-site scripting.

Rate limiting and throttling

Rate limiting controls the number of requests a user or IP can make within a specific time window, preventing systems from being overwhelmed by either malicious or overly aggressive traffic.

Throttling ensures fair use of resources and helps maintain service stability by slowing down or blocking excessive requests, especially on login pages, search features and APIs that are commonly targeted in application-layer DDoS attacks.

CAPTCHA and user validation

Adding human verification challenges like CAPTCHA to key user interactions (for example, login forms or contact pages) introduces friction that blocks automated attack traffic.

CAPTCHA mechanisms are a simple yet effective way to filter out bots attempting to generate large volumes of fake requests, which is common in layer 7 DDoS attacks meant to consume server processing power.

API gateway protections

API gateways serve as a control point for all API traffic, offering security capabilities such as authentication, IP filtering and request validation.

These features help detect and block malformed or excessive API calls that could overload backend systems. In modern web applications where APIs are heavily used, this layer is crucial for DDoS protection.

Optimise backend performance

Efficient backend systems are more resilient during attacks. Optimising database queries, implementing caching mechanisms and reducing dependency chains in service architectures help ensure that even during heavy traffic, whether legitimate or malicious, the infrastructure can continue to respond gracefully.

Code that performs unnecessary operations or resource-intensive tasks under pressure becomes a bottleneck and should be refactored.

5.3 Cloud and third-party services

Cloud-based DDoS protection services

Cloud DDoS mitigation providers offer large-scale, global infrastructure capable of absorbing and filtering massive volumes of malicious traffic. These services act as scrubbing centers where traffic is analysed, cleaned, and only then passed to the origin servers.

By offloading DDoS defense to providers like AWS Shield, Cloudflare or Akamai, organisations benefit from real-time threat intelligence and scalable protections without burdening their internal infrastructure.

Content delivery networks (CDNs)

CDNs cache static content at edge locations closer to the user, significantly reducing the load on origin servers.

By serving files like images, scripts, and stylesheets from these distributed nodes, CDNs help minimise the impact of DDoS attacks that aim to overload the origin. Additionally, many CDNs offer integrated DDoS mitigation features such as bot protection and geo-filtering.

Redundant DNS services

The Domain Name System (DNS) is a frequent target of DDoS attacks due to its critical role in service accessibility. Using multiple DNS providers with failover capabilities ensures continued name resolution even if one provider is attacked.

Services like Route 53, Cloudflare DNS, and Google Cloud DNS can be used in parallel for high availability and resilience against DNS-based amplification attacks.

Elastic auto-scaling

Cloud environments offer the ability to automatically scale resources in response to traffic spikes.

When under DDoS attack, auto-scaling can provide temporary relief by adding server instances or increasing bandwidth. While this doesn't stop the attack itself, it can maintain performance and availability while other mitigation steps are taken.

5.4 Detection and monitoring

Baseline normal traffic behaviour

Understanding what normal traffic looks like across various time periods helps in identifying anomalies indicative of a DDoS attack.

Baselines should account for seasonal fluctuations, marketing events and time-of-day usage. When deviations from these patterns occur, such as sudden, sustained spikes, alerts can be triggered to investigate further.

Deploy real-time monitoring tools

Monitoring tools that provide real-time visibility into network and application behaviour are vital for early detection.

Dashboards and alerting systems using tools like Prometheus, Grafana or commercial platforms can visualise traffic trends, connection counts, latency and error rates. Detecting unusual activity early allows teams to activate defenses before systems are overwhelmed.

Enable SIEM integration

Centralising log data from firewalls, web servers, WAFs and cloud services into a SIEM system enables correlation of events across layers.

SIEM platforms can automatically identify patterns that suggest an ongoing DDoS attack, support root cause analysis, and provide audit trails for post-incident review.

Use behavioural or AI-based anomaly detection

Advanced DDoS protection tools now include behavioural analytics and machine learning to identify attack patterns in real time.

These tools analyse user behaviour, traffic sources, and request types to distinguish between legitimate surges and malicious floods. This enables quicker, more accurate decision-making during fast-evolving incidents.

Alerting and escalation

Once an anomaly is detected, alerts must reach the right people with enough context to act quickly. Escalation workflows should ensure that network, security, and incident response teams are notified based on the severity of the event.

Integrating alerts into on-call systems like PagerDuty ensures timely response and minimises the duration of service degradation.

5.5 Incident response and recovery

Create a DDoS incident response plan

A documented response plan outlines exactly how to handle different types of DDoS attacks. It includes technical steps, roles and responsibilities, internal communication flows and vendor contact protocols.

Having a clear plan reduces panic, ensures consistency and allows for quicker action during live attacks.

Automate response actions

Where possible, predefined rules and scripts should automate portions of the DDoS response. For example, automated firewall rules can be triggered when traffic exceeds thresholds, or DNS records can be updated to redirect traffic through scrubbing centers.

Automation reduces time to response and minimises the chance of human error under pressure.

Engage external providers quickly

Many organisations rely on third-party vendors for protection. During an incident, knowing how and when to engage your cloud or DDoS mitigation providers is critical.

Pre-negotiated SLAs and support escalation paths should be documented and rehearsed to ensure fast collaboration.

Stakeholder communication

Transparent communication with internal stakeholders and customers is essential during a DDoS attack. Status updates should be timely and factual, avoiding overly technical language. Internal teams, such as customer support, executives and PR, must be aligned to ensure consistency in public messaging and manage reputational risk.

Isolate and recover

When necessary, isolating impacted services or regions helps prevent the attack from affecting other systems. Recovery involves restoring services, validating data integrity, and ensuring that infrastructure is stable.

This phase often overlaps with active mitigation, particularly when attacks are sustained over hours or days.

5.6 Ongoing security hygiene and improvement

Regular security updates

Applying timely updates to operating systems, applications and network appliances is fundamental to maintaining a secure environment. Unpatched vulnerabilities can be

exploited in combination with DDoS to amplify the impact or create backdoors. A routine patch management process helps reduce this risk.

Review and harden configurations

Security controls should not be 'set and forget'. Regular audits of firewall rules, WAF configurations and CDN settings ensure they remain aligned with the evolving threat landscape. Redundant or overly permissive rules should be removed, and rate limits should be fine-tuned based on actual usage.

Conduct DDoS drills and tabletop exercises

Simulating a DDoS incident, either through live technical drills or tabletop discussions, helps validate your response plan. These exercises identify gaps in your DDoS response activities.

6. DDoS incidents reporting

Major DDoS incidents should be formally reported depending on the type and impact.

Key reporting routes for major DDoS attacks

National Cyber Security Centre (NCSC)

- Report any serious cyber incident, including major or sustained DDoS attacks disrupting essential services
- Use the NCSC's [online incident reporting service](#) on GOV.UK
- The [Information Commissioner's Office \(ICO\)](#) may also forward cyber incident notifications to the NCSC if warranted.

Action Fraud / National Fraud Intelligence Bureau (NFIB)

- Report any ongoing or live DDoS attacks, especially those tied to criminal activity like extortion.
- Provide incident details and Action Fraud will forward them to NFIB and onward to local or national cybercrime units, such as the National Cyber Crime Unit (NCCU).

Information Commissioner's Office (ICO)

- If personal data is affected, you must still submit a GDPR-compliant breach report. The ICO offers information about [incident reporting](#).
- Voluntary submission to the NCSC is also advised if you need specialised support.

Regulatory reporting (as applicable)

- Organisations regulated under the UK's NIS Directive (for example, energy, transport, finance, health) must notify their specific competent authority, which may include Ofgem, Ofcom, the Financial Conduct Authority (FCA), the Department of Health and Social Care (DHSC), the ICO, the Bank of England and others. These bodies may have their own reporting thresholds and procedures.
- The CSO has information on [how to report cybercrime in the UK](#).

Legal and law enforcement channels

- In emergencies involving threats or extortion, call 999. For live cyber incidents, local police may still direct you to Action Fraud.

7. More information

[Denial of Service \(DoS\) guidance \(NCSC.GOV.UK\)](#)

[Azure DDoS protection overview \(Microsoft Learn\)](#)

[Application security - DDoS protection \(AWS Builder Center\)](#)